

Instead, it has lodged the complaint as a consumer of the product.

“That’s what makes this litigation unique and historic in terms of defending consumer rights,” says Karen M. Sandler, SFC’s executive director.

If SFC prevails, this case will give a significant boost to consumer rights, wherein not only the copyright holders of any open source component but the consumers also have the right for open source licence enforcement.

Establishing a compliance strategy

Identifying and tracking open source components and licences does not get the job done. In order to fully comply with the open source licence obligations, a compliance strategy needs to be implemented.

This compliance strategy should cover processes, policies and guidelines around onboarding the open source components, and educating team members on the obligations associated with open source licences.

The teams may include, but not be limited to, developers, product teams, stakeholders, legal teams, etc.

Delivering training to the employees: Training may include policy and guidelines set in place, which are required to be fulfilled before onboarding any open source component into the solution.

Regular training will help developers understand better the licensing basics and the importance of attribution concerns arising from using open source licences and sharing the source code if appropriate.

The compliance policies and processes may help in governing the various aspects of using, contributing, auditing, and distribution of open source software.

Software composition analysis: Software composition analysis (SCA) automates the process of gaining visibility into the components of a code base. SCA tools help in scanning an organisation’s

source code. These tools help to create an inventory, commonly known as software bill of materials (SBOM).

There are several SCA tools in the market that aim at identifying whether there is any licensing information or security threats present within the code.

OSRB (Open Source Review Board):

Another significant component of a compliance strategy is the OSRB (Open Source Review Board), which comprises a team of reviewers consisting of representatives from legal, engineering, and product teams; it helps to set the open source compliance strategy in place.

This board helps with any matters that relate to the use of open source components and determining the process of onboarding any open source component in the organisation. The OSRB reviews all the requests to incorporate open source code in products/services, evaluates these requests and approves/denies them based on technical and legal considerations.

Organisations such as the Linux Foundation have implemented this practice to ease the compliance process.

OpenChain standard

To safeguard your software’s code against any potential risks, quality compliance is the need of the hour. In order to build trust around open source

usage in the software supply chain and to ensure smooth product delivery, the OpenChain Project has introduced the ISO/IEC 5230 OpenChain standard. Started by the Linux Foundation and led by Shane Coughlan (general manager, OpenChain Project at the Linux Foundation), it has standardised a process for open source licence compliance. The standard defines clear guidelines that must be followed in order to achieve a conformant solution. Adopting these guidelines will help organisations develop a strong sense of confidence in their software bill of materials (SBOM). A recent bill passed in the United States mandates that the SBOM must contain details of components and vulnerabilities associated with the shipped product or solution.

Microsoft announced its conformance to the OpenChain specification in 2019. Many renowned organisations like Toyota, Cisco, and Uber have adopted the ISO/IEC 5230 and OpenChain standard as part of their compliance programmes. The ISO standard provides a benchmark framework, which ensures compliance related issues are reduced. It helps suppliers build trust in their software solution before releasing it into the market. **END** 🐧

References

- [1] ISO/IEC 5230:2020 – ISO standard
- [2] Open Chain – ISO specification
- [3] TLDR Legal – Software licences
- [4] ‘Guide To GPL Compliance’ – Software Freedom Law Centre
- [5] GitHub – Legal side of open source software
- [6] Microsoft – Microsoft’s internal open source program
- [7] NTIA – NTIA software component transparency
- [8] SPDX – SPDX licence
- [9] Cyclone DX- Cyclone DX Org
- [10] SFC – Software Freedom Conservancy
- [11] DHS Bill – DHS software supply chain
- [12] <https://www.forrester.com/report/The-State-Of-Application-Security-2020/RES159057?objectid=RES159057>

By: Sakshi Sharma

The author is an open source consultant at Source Code Control Limited.